



Weekly Cyber Threat Intelligence Report

Reporting window: 6 July - 13 July 2026

Australia - APAC - Global - Emerging Threats - IOCs to Add

Prepared for: Jordan

Classification: TLP:CLEAR - cleared for public release

Source: CyberSec Vault automated intel sweep

PUBLIC

Executive Summary



This week was defined by **emergency vendor advisories** and **same-week exploitation of internet-facing software**, a fast-widening **AI-agent and AI-tooling attack surface**, and **developer supply-chain compromises that abuse trusted publishing pipelines**. Adobe ColdFusion (CVE-2026-48282, CVSS 10.0) was exploited within minutes of a public technical analysis and added to CISA KEV; Progress issued a MOVEit-style **emergency shutdown** of on-prem ShareFile Storage Zone Controllers over a 'credible threat' (no CVE, no patch); and the Gitea Docker auth bypass (CVE-2026-20896) is under active exploitation via a single spoofed header. Microsoft shipped an out-of-band fix for the **RoguePlanet** Defender zero-day (CVE-2026-50656). The AI attack surface featured a Crawl4AI Docker unauth RCE (CVE-2026-57572, CVSS 10.0), and multiple AI-agent exploits - **Friendly Fire** and **Ghostcommit** prompt injection against code-review agents, the Claude Code worktree escape (CVE-2026-55607), and an OpenClaw one-WhatsApp-message RCE. Supply-chain: the **Injective SDK** npm compromise (wallet stealer), **jscrambler** (Rust infostealer across five versions), and 17 fake Paysafe/Skrill/Neteller SDKs. Espionage/regional: China-aligned **UNK_MassTraction** exploited Roundcube against universities, the **LapDogs (UAT-7810)** ORB actor added 'Leash' router backdoors, a **TONResolver** RAT used TON-blockchain C2 against Japanese hotels, and a dual-RAT fake Indian Income Tax campaign expanded. Australia saw a **CRITICAL ASD/ACSC alert** on large-scale CMS exploitation (plus an alleged Lifeline Australia leak). Breaches: AssuranceAmerica (6.9M licenses), Accenture (35GB source code), Mount Royal University (steal-then-wipe ransomware), and the Google/FBI NetNut takedown. Identity-based intrusion (Helix vishing, Forg365 PhaaS, Entra passkey-enrollment vishing) remained heavy. **Items are ordered verified-first, each with up to three independent references**; public PoCs/tools and indicators to add are in their own sections.

AUSTRALIA - SPECIFIC

Local orgs & advisories

ASD/ACSC alert - large-scale exploitation campaign targeting website CMS platforms

HIGH

VERIFIED

ASD

CMS

Exploitation

The Australian Signals Directorate's ACSC issued a CRITICAL-rated alert on 9 Jul over a large-scale campaign exploiting vulnerabilities in website content management systems globally, with many small/medium Australian businesses impacted. Actors scan for and exploit unauthenticated file upload, RCE, SSRF and deserialisation flaws in CMS software/plugins - primarily WordPress plugins, plus Craft CMS, Joomla JCE, MaxSite CMS and MetInfo CMS - to deploy webshells and gain remote control of web servers. Patch CMS core + plugins/themes, hunt for webshells and unexpected admin accounts, enforce MFA on admin panels.

Refs: [cyber.gov.au](#) · [bleepingcomputer.com](#) · [australiancybersecuritymagazine.com.au](#)

Lifeline Australia - employee dataset allegedly leaked (>10,600 records)

MEDIUM

UNVERIFIED

Breach

Australia

Alleged

A dark-web breach broker claims to have released more than 10,600 records tied to Lifeline Australia (national crisis-support / suicide-prevention organisation), with the visible sample reportedly containing employee and account data. Unconfirmed - no corroborating outlet or organisation confirmation found on web search at capture; retained UNVERIFIED as an alleged listing only. If validated: force employee credential resets, watch for staff-targeted phishing, and assess exposure of linked service accounts.

Refs: [x.com/DarkWebInformer](#)

APAC - SPECIFIC

Regional incidents & actors

Roundcube webmail exploited by China-aligned UNK_MassTraction to spy on university researchers

HIGH

VERIFIED

APT

China

Espionage

Proofpoint attributes (moderate confidence) an espionage campaign to China-aligned cluster UNK_MassTraction, exploiting now-patched critical Roundcube flaws (incl. CVE-2024-42009, an XSS triggered simply by opening a crafted email, CVSS 9.3) at US and Canadian universities since at least May 2026. After stealing credentials the actors deploy a web shell or the VShell post-exploitation tool and treat Roundcube mailservers as edge devices for network pivoting. Fewer than 10 universities observed targeted - physics/engineering departments and national-security research. Patch Roundcube, hunt for webshells/VShell, reset webmail credentials and enforce MFA.

Refs: bleepingcomputer.com · thehackernews.com · cyberscoop.com

China-linked APT (UAT-7810 / LapDogs) expands arsenal with new 'Leash' backdoors

HIGH

VERIFIED

APT

China

Backdoor

Cisco Talos reports the China-linked actor behind the LapDogs ORB (operational relay box) campaign - tracked as UAT-7810 - has expanded its SOHO-router malware toolkit with new backdoors LongLeash, DogLeash and JarLeash (an evolution of the ShortLeash backdoor that infected 1,000+ SOHO routers). UAT-7810 mainly exploits known Ruckus wireless-router flaws (CVE-2020-22653, CVE-2020-22658, CVE-2023-25717) with payloads for MIPS/ARM/x64. Related commentary flagged weak/auth-bypass features in Chinese-made consumer routers (e.g. TP-Link). Replace/patch edge routers, disable remote admin, and monitor router egress for anomalous C2.

Refs: securityweek.com · bleepingcomputer.com · blog.talosintelligence.com

TONResolver RAT abuses TON blockchain smart-contract C2 to hit Japan's hotel industry

HIGH

VERIFIED

Malware

Japan

BlockchainC2

Trend Micro (TrendAI Research) details a phishing campaign against Booking.com partner hotels in Japan that delivers TONResolver, a Node.js/JavaScript RAT storing its C2 domain inside a TON (The Open Network) smart contract (method get_domain). Because the operator can push a new domain to the contract at will, blocking a known server does not stop it - takedown-resistant C2. Delivery uses guest-complaint / review-request lures (bulk and interactive Gmail conversations) leading to malicious files, with VM-based obfuscation to hinder analysis. Detect on the phishing -> LNK/DLL side-load chain and monitor for outbound TON RPC lookups.

Refs: trendmicro.com · infosecurity-magazine.com · darkreading.com

Fake Indian Income Tax campaign drops dual RAT (Gh0st RAT + AsyncRAT) via DLL side-loading

HIGH

VERIFIED

Phishing

India

RAT

Cyderes details a broadening, six-stage campaign impersonating the Indian Income Tax Department. Fake Ministry-of-Finance pages (with a faux 'Microsoft Edge Secure Gateway' redirect) auto-download a ZIP (Common_Offline_Utility_ITR-1_to_4_AY2026-27.zip) that launches a signed-binary DLL side-loading chain deploying two implants with separate C2: a Gh0st RAT derivative to kxqhbh[.]top:6666 and an AsyncRAT-family RAT to ouewop[.]com:6351. Suspected China-nexus operators (possible Silver Fox overlap). Dual redundant C2 maximises persistence. Alert on paired RAT beaconing and tax-themed lures.

Refs: cyderes.com · thehackernews.com · csoonline.com

Tata Consultancy Services (Japan) - alleged ~400k-record dataset for sale (tcs-asia.org)

MEDIUM

UNVERIFIED

Breach

Japan

Alleged

A dark-web actor advertises ~400,000 records claimed to be associated with tcs-asia.org (TCS Japan), alleging origin from a CRM and customer-support platform. Unconfirmed, listing-only - no corroboration found; retained UNVERIFIED. CRM/support data would carry high phishing/vishing risk for named customers and support contacts. Monitor for TCS confirmation and correlate with the separate June TCS incident.

Refs: x.com/DailyDarkWeb

GLOBAL - ACTIVELY EXPLOITED & CRITICAL CVEs

[Patch now](#)**CVE-2026-48282 - Adobe ColdFusion max-severity path traversal -> RCE, exploited (CISA KEV)**

CRITICAL

VERIFIED

Adobe

RCE

Exploited

CVE-2026-48282 is a CVSS 10.0 path traversal in Adobe ColdFusion (part of the seven max-severity ColdFusion/Campaign fixes shipped 30 Jun) that can lead to arbitrary code execution. KEVIntel honeypots recorded exploitation from 2 Jul, minutes after watchTowr published a technical analysis; CISA added it to the KEV catalog with a 10 Jul federal deadline. Exploitation requires ColdFusion with RDS enabled and its authentication disabled. Upgrade to ColdFusion 2025 Update 10 / 2023 Update 21 immediately and hunt for unauthorised files in the web root and /CFIDE/.

PoC: Public - watchTowr technical analysis; exploited within minutes; CISA KEV (due 10 Jul) - helpnetsecurity.com

Refs: bleepingcomputer.com · securityweek.com · securityaffairs.com

Progress ShareFile - emergency shutdown of on-prem Storage Zone Controllers over 'credible threat'

CRITICAL

VERIFIED

Progress

ShareFile

Emergency

On 10 Jul Progress warned ShareFile customers to immediately and manually power down on-premises Storage Zone Controller Windows servers over a 'credible external security threat,' and temporarily disabled affected accounts 'out of an abundance of caution.' Only on-prem Storage Zone Controllers are affected (not cloud-only ShareFile). Progress has not disclosed the threat, whether a zero-day is involved, or any CVE - echoing the MOVEit mass-exploitation pattern. Keep servers down until a patched build ships; hunt for exfiltration/web shells and rotate ShareFile-adjacent credentials and API keys.

PoC: Suspected active exploitation - vendor-directed emergency shutdown; no patch/CVE at capture

Refs: thehackernews.com · bleepingcomputer.com · cybersecuritynews.com

CVE-2026-57572 - Crawl4AI Docker API unauthenticated RCE via Chromium arg injection (CVSS 10.0)

CRITICAL

VERIFIED

AI/LLM

RCE

Docker

CVE-2026-57572 (CVSS 10.0, CWE-88) is an unauthenticated argument-injection RCE in the Crawl4AI Docker API server (all versions < 0.9.0). User-supplied browser_config.extra_args is passed straight into Chromium's launch arguments without validation, so a single HTTP request injects launch switches that fork/execute an attacker command as the container's runtime user. A v0.8.9 denylist (proxy/DNS flags only) was insufficient. Upgrade to 0.9.0, which rejects extra_args at the boundary, enforces auth by default and binds to loopback. Companion CVE-2026-57573 (SSRF) also fixed in 0.9.0.

PoC: Prior partial fix (v0.8.9) insufficient; single request = full RCE - patch to 0.9.0 - ionix.io

Refs: nvd.nist.gov · tenable.com · ionix.io

CVE-2026-40008 - Apache IoTDB pipe processor unauthenticated deserialization RCE (CVSS 9.8)

CRITICAL

VERIFIED

Apache

RCE

Deserialization

CVE-2026-40008 (CVSS 9.8) is an unsafe-reflection RCE in the Apache IoTDB pipe processor: it reads a fully-qualified Java class name over the pipe-transfer RPC and instantiates it via Class.forName().newInstance() with no authentication and no allow-list, letting a network attacker instantiate arbitrary classes and reach code execution. Affects 1.0.0 before 2.0.10; fixed in 2.0.10 (credited Andrea Cosentino). Ships alongside a cluster of IoTDB pipe/AirGap advisories (CVE-2026-40005/-40006/-40007). Patch to 2.0.10 and never expose the IoTDB RPC interface to untrusted networks.

PoC: Unsafe reflection (Class.forName().newInstance()) over RPC, no auth - patch to 2.0.10

Refs: mail-archive.com · github.com · feedly.com

CVE-2026-20896 - Gitea Docker X-WEBAUTH-USER auth bypass (CVSS 9.8), exploited in the wild

HIGH

VERIFIED

Gitea

AuthBypass

Exploited

Attackers are actively exploiting CVE-2026-20896 (CVSS 9.8) in Gitea's official Docker image. The image ships `REVERSE_PROXY_TRUSTED_PROXIES=*` so, with reverse-proxy auth enabled, Gitea trusts a spoofed X-WEBAUTH-USER header from any source IP - a single crafted HTTP header lets an unauthenticated client become any user, including admin, exposing repos and secrets. Sysdig saw the first in-the-wild attempt 13 days after disclosure; ~6,200 Gitea instances are internet-exposed. Upgrade to 1.26.3/1.26.4 (latest) or restrict `REVERSE_PROXY_TRUSTED_PROXIES` to specific trusted IPs.

PoC: Active exploitation in the wild (first attempt 13 days after disclosure) - securityaffairs.com

Refs: bleepingcomputer.com · thehackernews.com · scworld.com

RoguePlanet (CVE-2026-50656) - Microsoft Defender zero-day EoP to SYSTEM, public exploit, patched

HIGH

VERIFIED

Microsoft

PrivEsc

ZeroDay

Microsoft shipped an emergency Malware Protection Engine update (1.1.26060.3008) on 9 Jul closing RoguePlanet (CVE-2026-50656), a Defender elevation-of-privilege / local-privilege-escalation flaw. It abuses a TOCTOU race in Defender's file-processing path to spawn a SYSTEM command prompt on fully-patched Windows 10/11. A researcher ('Nightmare Eclipse') published working PoC exploit code during a disclosure dispute, and Microsoft patched 29 days later. Confirm Defender platform/engine versions reflect the patched build across the fleet (engine updates deploy independently of the OS rollout).

PoC: Public - working exploit code published ('Nightmare Eclipse'); patched 29 days later - bleepingcomputer.com

Refs: bleepingcomputer.com · malwarebytes.com · theregister.com

CVE-2026-48062 - CodeIgniter4 ext_in upload validation bypass -> conditional RCE

HIGH

VERIFIED

PHP

FileUpload

RCE

CVE-2026-48062 is an upload-validation bypass in CodeIgniter4: the `ext_in` rule checked the MIME-derived guessed extension instead of the client-provided filename extension. On apps that accept user uploads, rely on `ext_in`, store files under the original client filename in a web-accessible directory and allow script execution there, it can lead to arbitrary code execution. All versions before 4.7.3 are affected; fixed in 4.7.3. Save uploads outside webroot, use `getRandomName()/store()`, and disable script execution in upload dirs.

PoC: Advisory GHSA-m6m8-6gq8-c9fj - fix in 4.7.3

Refs: github.com · advisories.gitlab.com · security.snyk.io

Langroid TableChatAgent - incomplete eval() mitigation -> sandbox escape RCE (CVSS 10.0)

CRITICAL

UNVERIFIED

AI/LLM

eval

RCE

Langroid's TableChatAgent executes model-generated code to answer questions over tabular data; a mitigation intended to constrain `eval()` is incomplete, letting attacker-influenced input escape the sandbox and run arbitrary Python (reported CVSS 10.0, no auth, GHSA-q9p7-wqyg-mrhc). Because such agents are often reachable over chat endpoints, the flaw is remotely exploitable. Single-source vendor-feed report at capture - retained UNVERIFIED pending broader corroboration. Upgrade to the fixed release and run any LLM-driven code/eval in a real container sandbox, not string filtering.

PoC: Advisory GHSA-q9p7-wqyg-mrhc - single vendor-feed source at capture

Refs: x.com/SecAlertsCo

GLOBAL - OTHER NOTABLE VULNERABILITIES

High severity

U-Boot - six FIT signature-verification flaws enable stealthy firmware attacks (BRLY-2026-037..042)

HIGH

VERIFIED

Bootloader

Firmware

Embedded

Six vulnerabilities (BRLY-2026-037 to -042) in the widely-used U-Boot bootloader are all reached while U-Boot is still reading an untrusted firmware image, before signature verification - so they bypass secure/verified boot. Two (BRLY-2026-037/-038) can lead to arbitrary code execution during firmware verification; the other four cause crashes (null-deref, unbounded recursion, improper validation). Most vulnerable code has existed since U-Boot 2013.07, potentially affecting 50+ releases and downstream vendor firmware (BMCs, networking gear, industrial/IoT). Track vendor firmware updates and prioritise network/edge and IoT fleets.

Refs: bleepingcomputer.com · thehackernews.com · cybersecuritynews.com

Zimbra Classic Web Client - critical stored XSS runs on email open (ZCS 10.1.19)

HIGH

VERIFIED

Zimbra

StoredXSS

Webmail

Zimbra patched a critical stored XSS in the Classic Web Client (fixed in ZCS 10.1.19, released 7 Jul; discovered by Google's Threat Analysis Group). A specially-crafted email runs malicious JavaScript when the message is opened, exposing mailbox contents, session data and account settings in the victim's authenticated webmail session. No CVE assigned yet and no confirmed exploitation, but Google-TAG involvement warrants urgency. Upgrade to 10.1.19, prefer the modern web client, and hunt for anomalous webmail sessions / settings changes.

Refs: bleepingcomputer.com · thehackernews.com · securityaffairs.com

Cisco Talos roundup - 3x WolfSSL, 14 GeoVision advisories (37 CVEs), 1x VTK-DICOM

HIGH

VERIFIED

Talos

IoT

Medical

Cisco Talos disclosed a cluster of vulnerabilities across a TLS library, physical-security IoT and a medical imaging toolkit. WolfSSL: three flaws (CVE-2026-28739, CVE-2026-25106 improper input validation; CVE-2026-33091 integer underflow) - broad embedded/IoT reach via static linking. GeoVision: 14 advisories covering 37 CVEs (memory corruption, OS command injection, buffer/stack overflow, privesc, reflected XSS) on frequently internet-exposed cameras. VTK-DICOM: CVE-2026-22879 heap buffer overflow (healthcare/OT). All patched by vendors. Inventory WolfSSL in embedded products, segment GeoVision devices off the internet, and update VTK-DICOM pipelines.

Refs: blog.talosintelligence.com · talosintelligence.com

CVE-2026-61857 - ImageMagick heap use-after-free via XMP profile parsing

MEDIUM

VERIFIED

ImageMagick

UAF

ImageParsing

CVE-2026-61857 is a heap use-after-free in ImageMagick (< 7.1.2-26) caused by a missing null check when parsing/printing XMP profiles in an invalid image. A crafted image delivered through any server-side pipeline (uploads, thumbnails, conversions) can trigger the condition with no user interaction. Public advisories score it MEDIUM/LOW (CVSS 6.3 v4.0 / 3.7 v3.1) - primarily a crash/DoS rather than confirmed RCE. Upgrade to 7.1.2-26, strip XMP metadata in upload pipelines where possible, and sandbox ImageMagick workers with a restrictive policy.xml.

PoC: Advisory GHSA-r83h-crwp-3vm7 - crash/DoS class (CVSS ~6.3); fix 7.1.2-26

Refs: github.com · vulncheck.com · cve.threatint.eu

CVE-2026-28564 - Apache IoTDB REST Basic Auth stale-credential replay bypass

HIGH

UNVERIFIED

Apache

AuthBypass

Replay

The Apache IoTDB REST API is reported to accept stale cached credentials, allowing an authentication bypass through capture-replay: an attacker who observes or replays a previously valid Basic Auth exchange can authenticate without current credentials, fully remote and no privileges (reported CVSS 9.8). Single vendor-feed source at capture - retained UNVERIFIED (though it accompanies the corroborated IoTDB pipe-processor advisory cluster). Patch to the fixed release, terminate REST behind TLS and an authenticating reverse proxy, rotate credentials and restrict endpoint exposure.

Refs: x.com/SecAlertsCo

CVE-2026-29509 - Das U-Boot NFS nfs_readlink_reply() buffer overflow

HIGH

UNVERIFIED

Bootloader

NFS

Overflow

A buffer overflow in U-Boot (<=2026.04-rc3) nfs_readlink_reply() when CONFIG_CMD_NFS is enabled: a malicious NFS server response fails to bound symlink data during readlink handling, corrupting memory during a network boot. An attacker controlling the NFS server (or on-path) can trigger it, affecting boot-time trust on embedded/IoT devices that netboot over NFS. Single-source (CVE feed) at capture - retained UNVERIFIED, and related to the broader six-flaw U-Boot disclosure. Update past 2026.04-rc3, disable CONFIG_CMD_NFS if unused, and avoid NFS boot over untrusted networks.

Refs: x.com/CVEnew

GLOBAL - SOFTWARE SUPPLY CHAIN

Dev & registry targeting

Injective Labs SDK (npm) - GitHub repo compromise pushes crypto wallet stealer (@injectivelabs/sdk-ts@1.20.21)

HIGH

VERIFIED

npm

Web3

WalletStealer

Attackers compromised the Injective Labs SDK GitHub repo (via a trusted contributor's account, abusing the repo's OIDC trusted-publisher pipeline) and published malicious @injectivelabs/sdk-ts@1.20.21 (released 8 Jul, ~50k weekly downloads, 310 downloads before deprecation). Fake 'telemetry' activates when SDK functions generate/import wallet keys, capturing the full mnemonic seed phrase and private key, base64-encoding them and exfiltrating via HTTP POST to an Injective-looking endpoint to blend in. Detected by Socket, Ox Security and StepSecurity. Pin/verify SDK versions, rebuild from a known-good commit, and rotate any wallet keys handled on affected machines.

Refs: thehackernews.com · bleepingcomputer.com · socket.dev

jscrambler npm package compromised - Rust infostealer via preinstall hook (8.14.0+)

HIGH

VERIFIED

npm

Infostealer

CICD

The official jscrambler npm package (a JS code-integrity/obfuscation client, ~15,800 weekly downloads) was compromised via a stolen publishing credential. Five malicious versions (8.14.0, 8.16.0, 8.17.0, 8.18.0, 8.20.0) were pushed over ~3 hours carrying the same cross-platform Rust infostealer; Socket detected it 6 minutes after publication. 8.14.0/8.16.0/8.17.0 run the payload from a preinstall hook, while 8.18.0/8.20.0 moved the dropper into main code/CLI so --ignore-scripts does not stop it. It targets cloud credentials, CI tokens, browser sessions, crypto wallets, Bitwarden vaults and AI-coding-tool configs (Claude Desktop, Cursor). Deny the malicious versions, audit lockfiles/CI caches and rotate exposed secrets.

Refs: socket.dev · thehackernews.com · safedep.io

Coordinated npm & PyPI campaign - 17 fake Paysafe/Skrill/Neteller SDKs harvest secrets

HIGH

VERIFIED

npm

PyPI

CredTheft

Socket's scanner flagged a cluster of at least 17 malicious packages (13 npm + 4 PyPI) published near-simultaneously on 7 Jul impersonating Paysafe, Skrill and Neteller SDKs (e.g. paysafe-checkout, skrill-sdk, neteller, paysafe-payments) with realistic function names. They exfiltrate Paysafe API keys, AWS keys, GitHub tokens, npm tokens, hostname/username and API metadata to an AWS-hosted C2. npm variants fire only if a Paysafe API key is present; PyPI variants auto-run on init. Sandbox/VM-evasion checks the hostname/username for 'sandbox/analyzer/cuckoo/vmware'. Block the packages, scan build pipelines/dev machines, and rotate integration credentials.

Refs: bleepingcomputer.com · socket.dev · cybersecuritynews.com

GLOBAL - PUBLIC PoCs & OFFENSIVE TOOL RELEASES

PoC / exploit code & tools

'Friendly Fire' - README prompt injection turns AI code-review agents (Claude Code / Codex CLI) into RCE

HIGH

VERIFIED

PromptInjection

AI-Agent

RCE

AI Now Institute researchers showed prompt injections spread across a third-party library's source and README hijack AI coding agents running in default auto-mode/auto-review - no hooks, plugins, MCP or config files needed. Because README.md is not an enforceable machine-config file, it needs no user approval, making it a broad, accessible vector. A benign geopy-based PoC adds a README recommending a 'security check' script (security.sh) plus a Go source file and precompiled code_policies binary that execute on review. Reported affecting Claude Code CLI (Sonnet 4.6/5, Opus 4.8) and OpenAI Codex CLI (GPT-5.5); no CVE, no in-the-wild use. Require human approval for tool/command execution on untrusted code; sandbox agent execution.

PoC: Public - payload-stripped PoC on GitHub (geopy-based; Boyan-MILANOV) - [github.com](#)

Refs: [ainowinstitute.org](#) · [thehackernews.com](#) · [cybersecuritynews.com](#)

CVE-2026-55607 - Claude Code sandbox escape via git-worktree path confusion (patched)

HIGH

VERIFIED

AI-Agent

SandboxEscape

RCE

CVE-2026-55607 (CVSS 7.7, GHSA-7835-87q9-rgvv, patched in Claude Code 2.1.163) chains three bugs - '.git' accepted as a worktree name, worktree creation following symlinks out of the project, and git-config indirection with write-to-\$HOME - so a prompt-injection-driven tool sequence reaches a worktree outside the sandbox and achieves unsandboxed host code execution, reportedly even in read-only + full-sandbox mode. Fresh amplification this window noted a ~\$3,700 bounty and a zsh/~/.zshenv variant (zsh sources ~/.zshenv before seatbelt restrictions). Isolate agents at the OS/container/VM layer; hunt for worktrees named .git and unexpected writes to \$HOME/global git config.

PoC: Public - Metnew write-up + GHSA-7835-87q9-rgvv; fixed in Claude Code 2.1.163 - [github.com](#)

Refs: [github.com](#) · [x.com/v_metnew](#) · [x.com/N4SHTOfficial](#)

OpenClaw - one WhatsApp message -> host RCE via three flaws (patched 2026.6.6)

HIGH

VERIFIED

AI-Agent

RCE

UntrustedInput

Three high-severity flaws in OpenClaw (self-hosted AI assistant wired to WhatsApp/Slack/Discord/Telegram/Teams; 381k GitHub stars, 100k+ daily users) let a single WhatsApp message achieve host code execution - no prior foothold. The core issue is sanitizeEnvVars() filtering env vars for credential leakage but not interpreter startup variables (NODE_OPTIONS, PYTHONSTARTUP, BASH_ENV), which preload attacker code before the target script runs. Researcher Chinmohan Nayak notes session memory lets attackers retry across new sessions. Patched in 2026.6.6. Treat inbound chat content as untrusted data, sandbox agent execution and require human confirmation for side-effectful actions.

PoC: Confirmed exploitable on 2026.6.1; fixed in 2026.6.6 - [thehackernews.com](#)

Refs: [thehackernews.com](#) · [cybersecuritynews.com](#) · [cyberpress.org](#)

Ghostcommit - prompt injection hidden in PNG images makes AI coding agents leak secrets

WATCH

VERIFIED

PromptInjection

ImagePayload

SecretsExfil

UMKC researchers demonstrated Ghostcommit (11 Jul): an AGENTS.md file that reads like build hygiene points to a PNG (docs/images/build-spec.png) whose rendered text instructs an agent to read .env byte-by-byte, encode each byte as an integer and emit it as a module constant (obfuscated exfiltration). Human and AI reviewers never open images - CodeRabbit excludes them by default - so the instructions pass review. Cursor and Antigravity followed the image and leaked .env under Sonnet/Gemini/GPT-5.5; notably Anthropic's Claude Code refused under every model tested, underscoring that safety depends on the implementation framework, not just the model. Treat images/binaries in PRs as untrusted; detect anomalous .env reads and obfuscated numeric encodings in diffs.

PoC: Public - research PoC (University of Missouri-Kansas City) - [bleepingcomputer.com](#)

Refs: [bleepingcomputer.com](#) · [cybersecuritynews.com](#) · [gbhackers.com](#)

CVE-2026-10104 - WooCommerce 'Product Video Gallery' authenticated stored XSS, public PoC

MEDIUM

UNVERIFIED

WordPress

StoredXSS

PoC

An authenticated stored XSS in the 'Product Video Gallery for WooCommerce' WordPress plugin (older versions) allows a contributor/author-level user to store JavaScript that executes on public product pages; a public PoC is on GitHub. Single-source (X bookmark) at capture - retained UNVERIFIED. Exploitability is higher with the PoC out: update or remove the plugin, review product pages for injected markup and audit low-privilege accounts.

PoC: Public - PoC on GitHub (Ravi-ik / liav-liv) - x.com/DarkWebInformer

Refs: x.com/DarkWebInformer

OpenWRT critical 0-day reportedly found via a self-built AI/LLM source-code vuln scanner

WATCH

UNVERIFIED

AI-Bugbounty

0day

OpenWRT

A researcher claims to have discovered and reported a critical OpenWRT 0-day using a home-built AI/LLM vulnerability-detection pipeline that ingests project source and has the model reason about it to surface flaws (specific bug undisclosed). Single-source social post (unverified) - a data point in the trend of LLM-driven source auditing producing real, reportable 0-days. Relevant to defenders (expect more AI-found bugs) and to bug-bounty methodology.

Refs: x.com/ridvanvagli

Metasploit weekly - Flowise CSV Agent exploit, Apache .htaccess persistence, macOS PackageKit privesc

INFO

UNVERIFIED

Metasploit

RedTeam

Modules

Rapid7's Metasploit weekly update added a Flowise CSV Agent exploit (LLM app-layer RCE class), an Apache .htaccess persistence technique, and a macOS PackageKit local privilege-escalation exploit. Single-source announcement (unverified). Red teams should pull the update to test detections; blue teams should build/verify detections for FlowiseAI abuse, unexpected .htaccess writes on Apache hosts, and PackageKit privesc on macOS fleets.

PoC: Public - new Metasploit modules (Rapid7) - x.com/metasploit

Refs: x.com/metasploit

VoidAuth - open-source self-hosted SSO / forward-auth identity provider

INFO

UNVERIFIED

Tool

SSO

Defensive

VoidAuth (github.com/voidauth/voidauth, voidauth.app) is an open-source SSO/user-management provider that fronts self-hosted apps as a forward-auth / identity layer (a niche comparable to Authelia/Authentik). Single-source release (unverified). Candidate SSO layer for homelab/self-hosted stacks - as an auth gateway, evaluate its own session handling, MFA and exposure before fronting sensitive apps.

Refs: x.com/DarkWebInformer

GLOBAL - MALWARE & CAMPAIGNS**EtherRAT - fake IT-support Teams calls deploy RAT with Ethereum smart-contract C2 (Unit 42)**

HIGH

VERIFIED

RAT

Teams

BlockchainC2

Palo Alto Unit 42 details a campaign chaining an 'Employee Survey' phishing PDF with a Microsoft Teams voice call from an external account impersonating a 'System Administrator' (observed account helpdesk@Progressive936.onmicrosoft.com, shown with the 'External unfamiliar' label). The victim is walked into installing EtherRAT via a Node.js loader; the RAT resolves its active C2 URL from an Ethereum smart contract (with a hard-coded fallback), making takedown harder. An open directory held installers v1-v9, indicating active development. Restrict external Teams messaging/screen-control, alert on MSI/PowerShell chains from Teams, and monitor for blockchain-RPC lookups.

Refs: bleepingcomputer.com · github.com · theregister.com

GodDamn ransomware - Microsoft-signed PoisonX driver (BYOVD) kills EDR incl. CrowdStrike Falcon

HIGH

VERIFIED

Ransomware

BYOVD

EDR-Evasion

Symantec's Threat Hunter Team disclosed GodDamn (9 Jul), the latest rebrand of Beast/Monster (actor 'Hyadina'), which uses the PoisonX kernel driver in a BYOVD attack to disable endpoint defenses before encryption. PoisonX is not a flawed legit driver but a deliberately malicious driver that passed Microsoft's signing review - it was first seen in early 2026 killing CrowdStrike Falcon via a crafted IOCTL to an undocumented interface, and 'has no flaw to patch.' A June intrusion also used AnyDesk and a NirSoft-based credential harvester before ransomware. Enforce the Microsoft vulnerable-driver blocklist (HVC/WDAC), don't trust publisher signature alone, and alert on the PoisonX driver hash and anomalous IOCTLs to security processes.

Refs: thehackernews.com · security.com · darkreading.com

Forg365 - AI-assisted phishing-as-a-service targeting Microsoft 365 (AiTM + device-code)

HIGH

VERIFIED

PhaaS

M365

AiTM

Forg365 is a new PhaaS focused on stealing Microsoft 365 accounts, combining device-code phishing and adversary-in-the-middle (AiTM) with AI-assisted lure generation, token/cookie management and a browser extension for continued access without re-auth. Distributed entirely via Telegram on a SaaS model (5-day free trial, \$400/mo, \$3,800/yr; ZeroBEC reporting). Device-code flow tricks victims into authorising an attacker device via legitimate OAuth 2.0; AiTM proxies the login to capture session cookies, defeating OTP/push MFA. Enforce phishing-resistant MFA (FIDO2/passkeys), monitor Entra sign-in logs for AiTM/device-code anomalies and restrict the device-code flow.

Refs: bleepingcomputer.com · cybersecuritynews.com · cyberpress.org

Helix - vishing/device-code extortion group exfiltrating SharePoint data

HIGH

VERIFIED

Vishing

SharePoint

Extortion

A new data-extortion group, Helix, uses vishing (often impersonating the victim's manager via name or caller-ID spoofing), device-code phishing and MFA abuse to breach Microsoft 365, then registers a new authenticator app for persistence and enumerates/exfiltrates from SharePoint before extorting or selling the data. ReliaQuest ties one Helix exfil IP to the same AS (51852) as a confirmed BlackFile IP, and notes a ShinyHunters-style playbook (employee impersonation, M365/SharePoint focus, NICENIC registrar). Highest-impact defence: disable device-code authentication where possible; harden help-desk identity verification and apply DLP on SharePoint mass-download.

Refs: bleepingcomputer.com · reliaquest.com · cybersecuritynews.com

Entra passkey-enrollment vishing ('Pink' / O-UNC-066) hijacks Microsoft 365 accounts

HIGH

VERIFIED

Vishing

Passkey

M365

Since April 2026 an actor tracked as O-UNC-066 ('Pink'; Unit 42 CL-CRI-1147) runs a panel-controlled phishing kit that walks Microsoft 365 users through enrolling an attacker-controlled Entra passkey. Victims are phoned under a 'register a new passkey for security' pretext and sent to phishing domains containing the word 'passkey.' An operator-controlled PHP panel steers the victim in near-real-time (1-second heartbeat polling), adapting to each victim's MFA (TOTP, push+number-matching, SMS OTP). The attacker's passkey provides durable, phishing-resistant-looking access that survives password resets. Okta saw targeting across food/beverage, tech, healthcare, automotive, construction and aviation; motive is data extortion. Alert on new passkey/FIDO2 registrations, especially post-call, and restrict who can self-enroll auth methods.

Refs: okta.com · bleepingcomputer.com · thehackernews.com

Fake big-brand job-interview phishing (30+ brands) steals Google accounts from marketers

MEDIUM

VERIFIED

Phishing

BrandImpersonation

Google

A five-month-running campaign impersonates 30+ well-known brands (Adobe, Adidas, Netflix, Coca-Cola, OpenAI, FIFA, Marriott, McKinsey, United/Delta/American Airlines, Louis Vuitton, etc.) with fake job-interview lures to steal Google credentials from marketing professionals. It abuses the legitimate PeopleForce HR platform and a Salesforce Marketing Cloud domain before redirecting to a credential-harvesting page, and uses the names/photos of real recruiters at the impersonated firms for credibility. The landing page's genuine-looking 'Continue with Google' button grants the attacker access. Treat unsolicited interview invites with external links as suspicious and use FIDO2/passkeys on Google accounts.

Refs: bleepingcomputer.com · darkreading.com · bitdefender.com

GigaWiper - Windows backdoor/wiper platform blends C2, ransomware and disk destruction

HIGH

UNVERIFIED

Wiper

Windows

Destructive

Malwarebytes reports GigaWiper, a Windows backdoor Microsoft has observed in intrusions since October 2025 - an operational platform (built from previously separate tools incl. Crucio ransomware and FlockWiper) that blends C2, remote access and data destruction. Destructive modes: a raw-disk wiper that overwrites in large chunks then forces reboot; a fake-ransomware wiper (Crucio-based) that encrypts then discards the key; and a multi-pass secure wipe of the Windows drive. Remote access includes screen capture/streaming and TCP keyboard/mouse control, with a scheduled task 'OneDrive Update' for persistence. Primarily single-origin reporting at capture - retained UNVERIFIED. Ensure tested offline/immutable backups; EDR alert on mass deletion, shadow-copy deletion and the persistence task.

Refs: malwarebytes.com

'Comment stuffing' in HTML phishing attachments to evade AI-based detection (SANS ISC)

MEDIUM

UNVERIFIED

Phishing

Evasion

AI-Bypass

SANS ISC analysed a phishing sample using 'comment stuffing' inside an HTML attachment to evade AI/ML-based detection: the HTML is padded with large volumes of comment content to dilute/confuse content classifiers while the functional payload still renders in the browser. Single-source (SANS diary) at capture - retained UNVERIFIED. Normalise/strip HTML comments before feeding content to ML classifiers, score on the rendered DOM, flag abnormal comment-to-content ratios, and detonate HTML attachments in a sandbox.

Refs: isc.sans.edu

Fraudulent 'Emergency Data Request' (EDR) services advertised to extract PII from providers

MEDIUM

UNVERIFIED

SocialEngineering

LegalProcessAbuse

PII

A threat actor is advertising fraudulent Emergency Data Request (EDR) services, offering user records from major tech and telecom platforms by abusing emergency-data-request procedures (which let providers disclose subscriber data without a warrant in life-threatening emergencies). Criminals forge or compromise official channels to submit fake EDRs and extract names, addresses, IPs and phone/email. Single-source dark-web listing (unverified). Commoditisation lowers the barrier to targeted PII acquisition (doxing, SIM-swap, stalking). Providers: harden EDR intake with out-of-band agency verification, official-portal validation and anomaly detection on EDR volume.

Refs: x.com/DailyDarkWeb

Reddit & Discord 'false report' scam weaponises abuse/appeal systems for account theft

MEDIUM

UNVERIFIED

Scam

Phishing

AccountTakeover

Malwarebytes details a 'false report' scam that steals Reddit and Discord accounts by weaponising the platforms' abuse/report and appeal flows - pressuring or tricking victims into fake support/appeal pages or coercing actions that hand over account access (complements the Discord CSAM false-flag ban-wave activity). Single-source at capture (unverified). Treat unsolicited 'your account was reported / appeal here' DMs and emails as phishing, navigate to official appeal flows manually, and enable MFA.

Refs: malwarebytes.com

GLOBAL - NOTABLE BREACHES

AssuranceAmerica - breach exposes ~6.9M drivers' license numbers and PII

HIGH

VERIFIED

Breach

Insurance

PII

US insurer AssuranceAmerica confirmed (9 Jul) a breach exposing driver's license numbers and PII of 6,998,886 people - the largest known US driver's-license spill this year. Attackers used a single employee's credentials to access systems on 16-17 March and exfiltrate data; a forensic review completed 15 Jun, with notifications from 10 Jul. Exposed: names, contact info, driver's license numbers, and auto-insurance policy/driver/vehicle/claims data, plus SSNs and Tax IDs for some. High identity-theft/fraud value - affected individuals should monitor for identity theft and consider credit freezes.

Refs: bleepingcomputer.com · malwarebytes.com · cybersecuritynews.com

Accenture - confirms breach after hacker claims 35GB source-code theft

HIGH

VERIFIED

Breach

SourceCode

CredentialTheft

Accenture confirmed a breach after a threat actor on 'PwnForums' claimed theft of ~35GB of data - source code, Azure access keys/tokens, config files, and RSA/SSH keys - posting a screenshot of a private Azure DevOps repo on an accenture.com domain as proof. Accenture says it contained and remediated the incident with no operational or service-delivery impact, but did not comment on the volume/type of data. Leaked keys/credentials could enable follow-on access to Accenture or client infrastructure and source code aids vulnerability discovery. Watch for credential-rotation and client-notification activity.

Refs: securityweek.com · bleepingcomputer.com · cybernews.com

Mount Royal University - ransomware (CMD Organization) stole then wiped H-drive data

HIGH

VERIFIED

Breach

Education

Ransomware

Mount Royal University (Calgary) confirmed a 17 June cyberattack in which the CMD Organization ransomware group stole data from specific folders on the H-drive (shared student/employee file storage) and wiped the originals to disrupt recovery. The actor published samples (passport scans and other sensitive documents) and demanded 30 BTC (~\$1.9M) with a six-day deadline before leaking the full set. MRU engaged external experts and is offering two years of credit/identity monitoring to current and recent (past five years) employees. Education-sector watch: monitor leak sites and phishing leveraging stolen data.

Refs: bleepingcomputer.com · securityweek.com · cbc.ca

Google / FBI / Lumen dismantle NetNut ('Popa') residential proxy - ~2M devices

HIGH

VERIFIED

Takedown

Botnet

Proxy

Google, with the FBI, Lumen and partners, dismantled the NetNut residential proxy network (tracked as 'Popa'), which co-opted at least ~2 million consumer devices (many Android smart-TVs/streaming boxes, plus apps bundling a hidden SDK). Google disabled the C2 accounts/services and updated Play Protect to warn on/disable NetNut-SDK apps; KrebsOnSecurity reports the FBI seized the platform (a note flags netnut[.]jio as the operational domain vs the seized netnut[.]com). Check mobile fleets for NetNut-SDK apps and hunt for residential-proxy SDK indicators and outbound proxy C2.

Refs: krebsonsecurity.com · bleepingcomputer.com · malwarebytes.com

Darsa AI - alleged 90-100GB leak (AI/CV model source + employee data)

MEDIUM

UNVERIFIED

Breach

AI-Company

Alleged

A forum actor claims Darsa AI (an AI safety/security company) was breached and posted a ~90-100GB leak including source code for AI models and computer-vision tools plus employee data. Unconfirmed, single-source dark-web listing (unverified). AI/CV model source plus employee PII raises IP-theft and social-engineering risk - watch for Darsa confirmation and downstream phishing of named employees.

Refs: x.com/DailyDarkWeb

monday.com - alleged user dataset for sale (>300k unique records)

MEDIUM

UNVERIFIED

Breach

SaaS

Alleged

A forum actor claims to be selling a monday.com dataset of >300,000 unique user records (account/user-level data tied to monday.com customers). Authenticity unconfirmed - could be scraped, reused or fabricated; single-source listing (unverified). If affiliated, treat as potential credential-stuffing/phishing fuel: enforce MFA and watch for targeted phishing of monday.com users.

Refs: x.com/DarkWebInformer

Lumos Gaming - alleged full platform compromise for sale (source + infra + customer data)

MEDIUM

UNVERIFIED

Breach

Gaming

Alleged

A threat actor advertises what they claim is a complete compromise of the Lumos Gaming platform, offering source code, infrastructure files and customer data. Unconfirmed, single-source listing (unverified). If affiliated, rotate credentials/secrets that could appear in leaked source or infra files and assume infrastructure-config exposure; monitor for a Lumos Gaming confirmation or breach notification.

Refs: x.com/DailyDarkWeb

INDICATORS OF COMPROMISE (IOCs) TO ADD

Blocklist / SIEM

Indicator	Type	Context	Reference
CVE-2026-48282	CVE	Adobe ColdFusion max-severity path traversal->RCE (10.0); exploited, CISA KEV	bleepingcomputer.com
CVE-2026-20896	CVE	Gitea Docker X-WEBAUTH-USER auth bypass (9.8); exploited - fix 1.26.3/1.26.4	bleepingcomputer.com
CVE-2026-50656	CVE	RoguePlanet Defender EoP->SYSTEM; public PoC - engine 1.1.26060.3008	bleepingcomputer.com
CVE-2026-57572	CVE	Crawl4AI Docker API unauth RCE (10.0); arg injection - fix 0.9.0	nvd.nist.gov
CVE-2026-40008	CVE	Apache IoTDB pipe processor unauth deserialization RCE (9.8) - fix 2.0.10	github.com
CVE-2026-48062	CVE	CodeIgniter4 ext_in upload validation bypass->RCE - fix 4.7.3	github.com
CVE-2026-61857	CVE	ImageMagick heap UAF via XMP profile (crash/DoS) - fix 7.1.2-26	github.com
CVE-2024-42009	CVE	Roundcube XSS exploited by UNK_MassTraction (China) vs universities	thehackernews.com
helpdesk@Progressive936.onmicrosoft[.]com	Account (Teams)	EtherRAT fake IT-support 'System Administrator' caller	github.com
@injectivelabs/sdk-ts@1.20.21	npm package	Injective SDK repo compromise - crypto wallet key/seed stealer	bleepingcomputer.com
jscrambler @ 8.14.0 / 8.16.0 / 8.17.0 / 8.18.0 / 8.20.0	npm packages	jscrambler supply-chain compromise (Rust infostealer)	socket.dev
paysafe-checkout / skrill-sdk / neteller / paysafe-payments	npm & PyPI	17 fake payment SDKs harvesting API/AWS/GitHub/npm secrets	bleepingcomputer.com
kkxqbh[.]top:6666	Domain:port (C2)	Gh0st RAT derivative - fake Indian Income Tax campaign	cyderes.com
ouewop[.]com:6351	Domain:port (C2)	AsyncRAT-family implant - fake Indian Income Tax campaign	cyderes.com
Common_Offline_Utility_ITR-1_to_4_AY2026-27.zip	Filename (lure)	Fake Indian ITR utility -> DLL side-load dual RAT	thehackernews.com
Scheduled task 'OneDrive Update' (every 1 min / at startup)	Host artifact	GigaWiper Windows backdoor/wiper persistence	malwarebytes.com

Indicator	Type	Context	Reference
AS198939 / stealthvm[.]net	ASN / Domain	CoolSSH / Throttle Limited bulletproof-hosting front (OSINT)	x.com/banthisquy9349

Defanged indicators - re-fang before importing. Verify against your environment before blocking.

TRENDS & EMERGING THREATS TO WATCH

Forward look

HIGH

Emergency advisories & same-week exploitation of internet-facing software

Why it matters: Adobe ColdFusion was exploited within minutes of a public write-up (CISA KEV), Progress ordered an emergency ShareFile shutdown with no patch or CVE, and the Gitea Docker auth bypass is live-exploited via one header. The gap between disclosure (or even a vendor's silent 'shut it down') and mass exploitation is now hours.

Watch for: unpatched internet-facing ColdFusion/Gitea/loTDB/Crawl4AI; vendor emergency-shutdown notices; CISA KEV additions; webshells and attacker-written files in web roots and on appliances.

HIGH

AI agents & AI tooling are a first-class attack surface

Why it matters: Friendly Fire and Ghostcommit turn 'review this repo' into RCE/secret theft via README and image prompt injection; the Claude Code worktree escape and an OpenClaw WhatsApp message both reach host code execution; and Crawl4AI's Docker API is an unauth 10.0 RCE. Notably, framework implementation - not just the model - decided who leaked secrets in Ghostcommit.

Watch for: AI code-review/coding agents acting on untrusted repos, images or chat messages without human-in-the-loop; exposed AI dev-tool APIs (Crawl4AI, Flowise, Langroid); interpreter env vars (NODE_OPTIONS/BASH_ENV) reaching spawned processes.

HIGH

Developer supply-chain compromise via trusted publishing pipelines

Why it matters: The Injective SDK repo was poisoned through its own OIDC trusted-publisher flow, jscrambler shipped a Rust infostealer across five versions from a stolen npm credential, and 17 fake payment SDKs harvested cloud/CI secrets - malware that executes at install or import and increasingly targets AI-tool configs, wallets and CI tokens.

Watch for: install-time/import-time execution and preinstall hooks; new/anomalous maintainer or publish credentials; packages exfiltrating to cloud endpoints; rebuild recent npm/PyPI installs and rotate developer, cloud, CI, wallet and SSH secrets.

HIGH

Identity-first intrusion: vishing, device-code and passkey-enrollment abuse

Why it matters: Helix (vishing + device-code -> SharePoint exfiltration), Forg365 PhaaS (AiTM + device-code + AI lures), and the 'Pink'/O-UNC-066 passkey-enrollment vishing campaign all bypass or co-opt MFA by abusing user trust and enrollment flows, with durable attacker-controlled passkeys surviving password resets.

Watch for: new passkey/FIDO2 or authenticator registrations (especially post phone call); anomalous device-code grants; help-desk-driven MFA resets; SharePoint mass-download; impossible-travel sign-ins.

MED

China-nexus espionage and takedown-resistant blockchain C2 in APAC

Why it matters: China-aligned UNK_MassTraction exploited Roundcube against universities, LapDogs (UAT-7810) expanded its 'Leash' router-backdoor ORB network, and a TONResolver RAT stored C2 in a TON smart contract to hit Japanese hotels - patient, infrastructure-and-edge-focused tradecraft that resists takedown.

Watch for: Roundcube/edge-device exploitation and VShell; SOHO/Ruckus router compromise and anomalous egress; outbound TON/blockchain-RPC lookups from endpoints; guest-complaint and tax-themed lures across APAC.

MED

Signed-driver BYOVD and destructive malware raise the EDR-evasion bar

Why it matters: GodDamn ransomware uses a Microsoft-signed PoisonX driver 'with no flaw to patch' to kill CrowdStrike Falcon, and GigaWiper blends C2, fake-ransomware and multi-pass disk wiping - both defeat naive publisher-trust and backups-as-only-defence assumptions.

Watch for: unexpected kernel driver loads and anomalous IOCTLs to security processes; the Microsoft vulnerable-driver blocklist (HVCI/WDAC) disabled; mass file/shadow-copy deletion; presence of tested offline/immutable backups.

PRIORITY ACTIONS THIS WEEK

Area	Action
Patch now	Adobe ColdFusion 2025 U10 / 2023 U21 (CVE-2026-48282); Gitea -> 1.26.3/1.26.4 (CVE-2026-20896); Microsoft Defender engine 1.1.26060.3008 (RoguePlanet/CVE-2026-50656); Crawl4AI -> 0.9.0 (CVE-2026-57572); Apache IoTDB -> 2.0.10 (CVE-2026-40008); Codelgniter4 -> 4.7.3 (CVE-2026-48062); Zimbra -> ZCS 10.1.19; ImageMagick -> 7.1.2-26 (CVE-2026-61857); U-Boot firmware updates; OpenClaw -> 2026.6.6; Claude Code -> 2.1.163.
Emergency / no-patch	ShareFile: keep on-prem Storage Zone Controllers powered down per Progress until a fixed build ships; hunt for exfil/web shells and rotate ShareFile secrets/API keys. Langroid/IoTDB REST replay: restrict exposure and sandbox eval pending fixes.
Block IOCs	Add the IOC-table indicators (ColdFusion/Gitea/Crawl4AI/IoTDB/Defender CVEs, EtherRAT Teams account, Injective/jscrambler/fake-payment npm+PyPI package names, kxqbh[.]top:6666 & ouewop[.]com:6351, ITR ZIP lure, GigaWiper 'OneDrive Update' task, AS198939/stealthvm[.]net) to firewall/EDR/SIEM blocklists and alert on the listed CVEs.
Assume compromise	Treat internet-exposed ColdFusion, Gitea Docker, on-prem ShareFile, Crawl4AI/IoTDB and Roundcube as potentially compromised - hunt for webshells/VShell, attacker-written files and anomalous access; rotate appliance/app secrets and SAML material.
Supply chain	Rebuild recent npm/PyPI installs; deny the named malicious versions; audit lockfiles and CI caches; use --ignore-scripts for untrusted installs (note some payloads run on import); rotate developer, cloud, CI, wallet, Bitwarden and SSH secrets; verify trusted-publisher/OIDC pipelines.
AI / agents	Require human-in-the-loop for AI code-review/coding-agent tool execution on untrusted repos, images and chat; treat repo docs/images/messages as untrusted data; put Crawl4AI/Flowise/Langroid behind auth and off the internet; audit interpreter env-var handling in agent runners.
Identity	Enforce phishing-resistant MFA (FIDO2/passkeys) on Microsoft/Entra; disable the device-code flow where unneeded; restrict and alert on new passkey/authenticator enrollments; harden help-desk verification against vishing; DLP on SharePoint mass-download.
Endpoints & people	Enforce the Microsoft vulnerable-driver blocklist (HVCI/WDAC) and don't trust publisher signature alone (PoisonX); ensure tested offline/immutable backups (GigaWiper); brief staff on Teams IT-impersonation, fake job-interview and false-report lures; audit CMS/plugins and browser extensions.